

学与成设计网

安全审计报告

审计对象: <https://www.xuedda.com>

审计日期: 2026 年 5 月 18 日

框架识别: LzCMS v1.1.4 / Nginx / PHP

审计范围: 公网可访问资产 (前端 + 后台入口 + 配置泄露)

密级: 内部

一、风险概览



审计共发现 12 个安全问题。严重问题均涉及后台访问控制失效与 CMS 版本信息泄露；高危问题集中于 Cookie 安全与请求伪造防护缺失。

二、目标环境信息

服务器	Nginx
语言 / CMS	PHP · LzCMS v1.1.4 (老张CMS)
HTTPS	✅ 已启用 / HSTS max-age=31536000
管理后台	https://www.xuedda.com/admin/index/index.html (公网可达)
上传目录	/uploads/images/YYYYMMDD/ (403 禁止列目录，但文件可直链访问)
Cookie	PHPSESSID (缺少 HttpOnly / Secure / SameSite)

三、漏洞详情

严重 C-01 • 管理后台公网暴露

后台登录页 `/admin/index/index.html` 可被任意公网用户直接访问，无 IP 白名单、无 VPN 限制、无二次认证。

攻击者可对后台登录接口进行暴力破解、撞库攻击；若用户名密码泄露，可直接接管全站内容。

🔧 修复建议

1. Nginx 层对 `/admin/` 加 IP 白名单：

```
location /admin/ {  
    allow 你的办公IP;  
    deny all;  
}
```

2. 后台登录增加 MFA (TOTP) 二次验证。
3. 敏感操作 (删除/批量修改) 二次确认码。

严重 C-02 • CMS 版本信息明文泄露

页面底部显示 `Powered by LzCMS! v1.1.4`，后台登录页标题为 `LzCMS-后台管理中心`。

攻击者可依据公开的 LzCMS v1.1.4 漏洞库 (如文件上传、SQL 注入、RCE) 直接构造攻击载荷。

🔧 修复建议

1. 删除或修改 CMS 版权标识。
2. 后台登录页标题改为通用的 "管理登录" 或 "Admin Login"。
3. 修改默认后台路径，如一键更换后台入口目录。

高危 H-01 • Cookie 缺少安全标记

Set-Cookie: PHPSESSID=xxx; path=/ 缺少 HttpOnly、Secure、SameSite 属性。

XSS 攻击可读取 session cookie 并劫持用户身份；中间人攻击可窃取 cookie。

修复建议

PHP 配置 php.ini：

```
session.cookie_httponly = 1
session.cookie_secure = 1
session.cookie_samesite = "Lax"
```

高危 H-02 • 缺少安全响应头

网站未返回 Content-Security-Policy、X-Frame-Options、X-Content-Type-Options 等安全头。

修复建议

Nginx 配置添加：

```
add_header Content-Security-Policy "default-src 'self'; script-src 'self' 'unsafe-
add_header X-Frame-Options "SAMEORIGIN";
add_header X-Content-Type-Options "nosniff";
add_header Referrer-Policy "strict-origin-when-cross-origin";
add_header Permissions-Policy "geolocation=(), microphone=()";
```

高危 H-03 • ID 遍历 / 接口枚举

URL 使用自增 ID： /index/download/show/id/1.html，访问不存在的 ID 返回 500 而非 404。

攻击者可遍历所有资源记录，批量抓取整站数据；500 错误可能回显数据库报错信息（SQL 注入风险）。

修复建议

1. 资源不存在时统一返回 404，不输出数据库错误。
2. 未登录/非会员无法访问会员资源时应返回 403。
3. 长期方案：资源 slug 化或用 UUID 替代自增 ID。

中危 M-01 • robots.txt 暴露后台路径

`robots.txt` 内容为: `Disallow: /admin/`。虽然禁止搜索引擎抓取,但也直接告诉了攻击者后台所在。

修复建议

如果已改后台入口目录,可将 `robots.txt` 设为通配 `Disallow: /` 或删除后台路径声明。

中危 M-02 • 登录表单无 CSRF 防护

前台登录页面未见到 CSRF Token; 攻击者可伪造请求诱导用户执行非预期操作。

修复建议

所有状态变更请求 (POST/PUT/DELETE) 添加 CSRF Token, 服务端校验。

中危 M-03 • 上传目录文件可预测访问

图片路径格式为 `/uploads/images/20260517/xxx_thumb_320_180.jpg`, 按日期+文件名模块, 可被预测枚举。

修复建议

1. 会员资源的上传图片应通过鉴权接口代理输出而非直接暴露。
2. 文件名使用 UUID 命名, 避免可预测。

中危 M-04 • 无登录失败限制 / 验证码

后台和前台登录均未见验证码或失败次数限制, 可被暴力破解。

修复建议

1. 同一 IP / 账号连续失败 5 次锁定 15 分钟。
2. 添加数学题验证码或滑动验证码。

低危 L-01 • 软件版权风险

网站分发大量「和谐版」商业软件（SU2025、ENS4.0 等），存在 DMCA/著作权侵权风险。

🔧 修复建议

建议只保留免费/开源软件和原创教程，降低法务风险。

低危 L-02 • 无备份与日志监控

未见 WAF 或异常访问告警机制，攻击发生后难以追溯。

🔧 修复建议

接入 Cloudflare WAF / 安全组，开启 Nginx access log 分析，定期备份数据库与文件。

低危 L-03 • 第三方资源未校验完整性

页面引用了第三方图片及外部域名（qqimg.com、bilibili.com 等），未使用 SRI 校验。

🔧 修复建议

可使用 CSP `require-sri-for` 或对关键 JS 资源添加 `integrity` 属性。

四、当前旧站 vs Next.js 新站对比

❌ 当前旧站 (LzCMS / PHP)

- 后台路径暴露
- CMS 版本公开
- Cookie 无 HttpOnly/Secure
- 无 CSP / HSTS 不完整
- 自增 ID 可枚举
- 500 错误泄露细节
- 无 CSRF 防护
- 无登录失败限制

✅ 新站规划 (Next.js 16 + Prisma + PostgreSQL)

- 内置 middleware 鉴权路由守卫
- 无版本标识泄露
- Session cookie 全属性标记
- 统一安全头中间件
- Slug / UUID 路由
- 统一错误页 + 日志分离
- next-auth / CSRF token 原生支持
- Rate limiting + 验证码

五、Next.js 新站安全加固方案

5.1 推荐技术栈

Next.js 16 (App Router)

next-auth / Auth.js

Prisma + PostgreSQL

Zod 校验

Helmet.js

Cloudflare WAF

Rate Limiting

Argon2 密码哈希

5.2 安全加固清单

#	措施	实现方式	优先级
1	后台路径隐藏	使用自定义 basePath 或反向代理映射，不走 <code>/admin</code> 常见路径	严重
2	Admin 中间件鉴权	在 <code>middleware.ts</code> 中校验 session role，非 ADMIN 重定向 404	严重
3	Next.js 安全头	<code>next.config.ts</code> 中配置 headers() 注入 CSP 等安全头	高危
4	Cookie 安全	Session cookie 设置 httpOnly / secure / sameSite='lax'	高危
5	Rate Limiting	登录/API 接口使用 <code>upstash/ratelimit</code> 或 Redis 计数限流	高危
6	CSRF 防护	next-auth 自带 CSRF token；纯 API 使用 SameSite Cookie + Origin 头校验	中危
7	输入校验	所有 API route 入参用 Zod schema 校验，防止注入	中危
8	统一错误处理	全局 <code>error.tsx</code> 和 <code>not-found.tsx</code> ，不暴露堆栈	中危
9	资源 Slug 化	文章/下载使用 slug 代替自增 ID，数据库保留 ID 仅作内部引用	中危
10	文件上传安全	校验 MIME 类型、文件大小限制；非公开资源走鉴权代理下载	中危
11	MFA 支持	接入 TOTP (<code>speakeasy/otplib</code>)，管理员强制二次验证	低危
12	审计日志	管理员操作写入 AuditLog 表，关键操作不可删除	低危

5.3 关键代码示例

middleware.ts — Admin 路由守卫


```
// src/middleware.ts
import { NextResponse } from 'next/server';
import type { NextRequest } from 'next/server';
import { getToken } from 'next-auth/jwt';

export async function middleware(req: NextRequest) {
  const token = await getToken({ req, secret: process.env.AUTH_SECRET });
  const isAdmin = token?.role === 'ADMIN';

  if (req.nextUrl.pathname.startsWith('/admin')) {
    if (!isAdmin) {
      return NextResponse.redirect(new URL('/404', req.url));
    }
  }
  return NextResponse.next();
}

export const config = { matcher: ['/admin/:path*'] };
```

next.config.ts — 安全响应头

```
// next.config.ts
import type { NextConfig } from 'next';

const nextConfig: NextConfig = {
  async headers() {
    return [{
      source: '/(.*)',
      headers: [
        { key: 'X-Frame-Options', value: 'SAMEORIGIN' },
        { key: 'X-Content-Type-Options', value: 'nosniff' },
        { key: 'Referrer-Policy', value: 'strict-origin-when-cross-origin' },
        { key: 'Permissions-Policy', value: 'camera=(), microphone=(), geolocation=()' },
        {
          key: 'Content-Security-Policy',
          value: "default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'u"
        }
      ],
    }];
  },
};

export default nextConfig;
```

API Route — 输入校验 (Zod)

```
// src/app/api/download/route.ts
import { NextRequest, NextResponse } from 'next/server';
import { z } from 'zod';

const DownloadInput = z.object({
  title: z.string().min(1).max(200),
  url: z.string().url(),
  password: z.string().max(100),
  categoryId: z.number().int().positive(),
  sortOrder: z.number().int().min(0),
});

export async function POST(req: NextRequest) {
  const body = await req.json();
  const parsed = DownloadInput.safeParse(body);
  if (!parsed.success) {
    return NextResponse.json({ error: '参数校验失败' }, { status: 400 });
  }
  // 写入数据库...
}
```

登录限流 (Upstash Redis)

```
// src/lib/rate-limit.ts
import { Ratelimit } from '@upstash/ratelimit';
import { Redis } from '@upstash/redis';

export const loginRateLimit = new Ratelimit({
  redis: Redis.fromEnv(),
  limiter: Ratelimit.slidingWindow(5, '15 m'),
  analytics: true,
});

// 在 API route 中使用
const { success } = await loginRateLimit.limit(req.ip ?? 'unknown');
if (!success) {
  return NextResponse.json({ error: '操作过于频繁，请15分钟后重试' }, { status: 429 });
}
```

六、修复优先级路线图

阶段	时间	内容
P0 紧急	1-3 天	Nginx IP 白名单限制 /admin/; 删除 CMS 版本标识; 配置基础安全头
P1 高优	1-2 周	Cookie 安全标记; CSRF 防护; 登录失败限制 + 验证码
P2 中优	1 个月	Next.js 新站 admin 中间件; Zod 输入校验; 统一错误处理; 资源 Slug 化
P3 低优	持续	MFA 支持; 审计日志; WAF 接入; 第三方资源 SRI

七、附录

A. 旧站问题对应新站解决方案映射

旧站问题	新站 (Next.js) 对应方案
后台路径暴露	middleware.ts 路由守卫 + 自定义 basePath
CMS 版本泄露	不输出任何框架标识
Cookie 不安全	next-auth / 自定义 session cookie 全属性
无安全头	next.config.ts headers()
ID 遍历	Slug 路由 + Prisma 参数化查询
500 错误泄露	全局 error.tsx / error boundary
无 CSRF	next-auth CSRF token / SameSite Cookie
无限流	Upstash Ratelimit / Redis
SQL 注入风险	Prisma ORM 天然参数化
上传无校验	Zod 校验 + MIME 过滤 + 大小限制

B. Nginx 建议配置 (旧站应急加固)

```
# 后台 IP 白名单
location /admin/ {
    allow 123.456.789.0;    # 替换为实际办公 IP
    deny all;
}

# 隐藏 Nginx 版本号
server_tokens off;

# 通用安全头
add_header X-Frame-Options "SAMEORIGIN" always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-XSS-Protection "1; mode=block" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;

# 限制请求速率
limit_req_zone $binary_remote_addr zone=login:10m rate=5r/m;
location /index/member/login.html {
    limit_req zone=login burst=3 nodelay;
}
```

本报告为内部安全审计产出，仅供 xuedda.com 技术团队参考，请勿外传。

生成时间：2026-05-18 · 审计工具：手工探测 + 公网信息收集